SHIELD-AI(TM): Tooling and Process Map

Tools and Processes to Address All 59 Controls, Assessed with Six Thinking Hats

Security Architecture Practice

August 6, 2026

Abstract
A map of the tools and processes that can be implemented to address every control in the SHIELD-AI framework (v1.7, 59 controls across 7 pillars). Each identified tool or process is analysed with the Six Thinking Hats method for its strengths and weaknesses specifically with respect to SHIELD-AI. The report closes with a coverage analysis of controls that lack mature tooling and a maturity-aligned adoption roadmap (L1-L4).

SHIELD-AI Tooling and Process Map

1. Executive Summary

This document maps every one of the 59 SHIELD-AI controls to a concrete tool or process that can implement it, then evaluates each candidate with the Six Thinking Hats method. Three findings matter most:

- **About two-thirds of the controls are addressable with mature, mainstream tooling.** Identity, policy, gateway, sandbox, logging, scanning, and governance controls map onto tools most security teams already run (OPA, Vault, SPIFFE, API gateways, Kubernetes policy engines, SIEM, SBOM scanners, HSM/KMS).
- **Eleven controls have no mature commercial tool** and require custom or emerging implementation: MS-07 (deployment-context obfuscation), MS-09 (perception-fidelity enforcement), MS-10 (agent memory-store integrity), MS-11 (operational data-stream integrity), DS-07 (artifact publication control), TP-07 (cross-tool dependency analysis), TP-10 (inbound control-plane protection),

TP-11 (agent browser and content-rendering isolation), TP-12 (tool-call provenance and dispatch verification), EE-07 (control-plane configuration integrity), and EE-08 (evaluation-harness isolation). The SHIELD-AI reference implementation exists precisely to cover these.

- **The highest-leverage adoption sequence is L2-baseline first**: identity and policy (SPIFFE, Vault, OPA), sandboxing, gateway, and logging make every later control cheaper to add. Maturity-led adoption beats tool-led adoption.

A control-to-tool mapping covering all 59 controls is in Part A; the per-tool hats analyses are in Parts B and C; coverage gaps and the adoption roadmap are in Parts D and E.

2. Method: How the Tools Were Assessed

Each tool and process in Parts B and C is assessed with the Six Thinking Hats method (DeBono). The hats are used as evaluation lenses, applied to the single question: *how well does this tool serve SHIELD-AI?* The sequence per tool is White (facts) to Black (weaknesses) to Yellow (strengths) to Red (gut) to Green (creative integration) to Blue (verdict).

Hat	Lens applied to each tool
White	What the tool is, what it does, maturity, deployment model
Black	Weaknesses and risks with respect to SHIELD-AI: coverage gaps, bypass-by-design, config drift, fail-open behaviour, operational burden, lock-in
Yellow	Strengths: which controls it implements, where it fits an L1-L4 path, ecosystem leverage
Red	Gut reaction: would a security team actually run it, or will it be disabled at the first friction point
Green	Creative integration: how the tool can be extended or combined to serve SHIELD-AI beyond its stock role
Blue	Verdict: adopt / adopt with adaptation / process-only / custom build, plus the controls it addresses

Tool identifiers (T1-T27) and process identifiers (P1-P14) are used in the Part A mapping table.

Two additional rows appear in every catalogue entry: **Links** (official site, docs, and source repositories) and **Options** (commercial offerings, FSS (free and open-source software) alternatives, and cloud-specific equivalents across AWS, Azure, and GCP). Where a category has no mature option, that is stated explicitly rather than filled with a weak substitute.

Part A: Control-to-Tool Mapping (All 59 Controls)

A1. Model Security (MS-01 .. MS-11)

Control	Tool / Process	Notes
MS-01 Model weight protection	T4 HSM/KMS; T3 Vault Transit	Encrypt weights at rest and in transit; HSM-backed keys for L3+
MS-02 Training data integrity	P6 Training data governance; T16 classification platforms	Provenance tracking, sanitisation, poison detection
MS-03 Model supply chain security	T5 Model registry + signing; T9 Sigstore	Signed checkpoints, ML SBOM
MS-04 Adversarial robustness	T6 Garak/PyRIT/ART; T7 promptfoo	Prompt-injection and jailbreak testing in CI; imperceptible-content scanning (custom, see MS-09)
MS-05 Model behaviour validation	T8 Guardrails (NeMo/Guardrails AI/LLM Guard)	Output guardrails, behavioural bounds

Control	Tool / Process	Notes
MS-06 Model inventory and lineage	T5 MLflow Model Registry	Catalogue, versions, provenance
MS-07 Deployment context obfuscation	P11 (custom process)	No commercial tool; custom environment-indistinguishability testing
MS-08 MCP security	T12 MCP gateway + MCP Inspector; T1 OPA	Signed tool metadata, authenticated gateway, schema validation
MS-09 Perception-fidelity enforcement	P12 (custom workflow) + T7 (partial)	Snapshot-binding of approvals; emerging; custom
MS-10 Agent memory-store integrity	T15 vector DB access control + T18 observability + T20 audit	Memory-write audit, tamper-evident stores, retrieval filtering; mature via composition

A2. Identity and Access (IAM-01 .. IAM-09)

Control	Tool / Process	Notes
IAM-01 Agent identity management	T2 SPIFFE/SPIRE	Unique, workload-level identities per agent
IAM-02 Scope-bound delegation	T1 OPA; T14 OpenFGA/Cedar	No wildcards; per-agent scopes

Control	Tool / Process	Notes
IAM-03 Human oversight controls	T27 CI approval gates; P13 approval workflows	Approval gates for high-risk actions
IAM-04 Credential isolation	T3 Vault	Agent credentials separate from human credentials; hardware-backed at L3+
IAM-05 Just-in-time access	T3 Vault (dynamic secrets); T4 KMS	Ephemeral credentials, auto-revocation
IAM-06 Cross-session boundary enforcement	T15 Vector DB session scoping; T3	Session-isolated identity contexts
IAM-07 Delegation chain enforcement	T1 OPA; T2 SPIFFE (token chaining); T14	Two-hop bound, reconstructable chains
IAM-08 Credential scope narrowing	T3 Vault (per-tool roles); T1 OPA	Per-tool scoped credentials, cascade revocation
IAM-09 Multi-tenant agent platform isolation	T14 OpenFGA (tenant scoping); T1 OPA	Tenant ID in every query; row-level security

A3. Data Security (DS-01 .. DS-07)

Control	Tool / Process	Notes
DS-01 Data classification and labelling	T16 Purview/BigID/Macie	Automated tagging at ingestion
	T11 API gateway (TLS); T4 KMS	

Control	Tool / Process	Notes
DS-02 Inference data protection		TLS 1.3 minimum, end-to-end encryption
DS-03 Memory sanitisation	T15 Vector DB session scoping	No persistence beyond session; namespace isolation
DS-04 Data minimisation	T14 OpenFGA; T15 retrieval-layer filtering	Field-level filtering, no bulk access
DS-05 Training data governance	P6 (process)	Lineage, consent, retention limits
DS-06 Output validation (leak detection)	T17 DLP; T18 LLM observability	Automated scanning for PII/ data leakage
DS-07 Artifact publication control	P13 (workflow) + T9 Sigstore + T27 CI gates	Agent-authored artifacts through the third-party vetting pipeline; out-of-band approval

A4. Tool and Pipeline Security (TP-01 .. TP-12)

Control	Tool / Process	Notes
TP-01 Tool inventory and registry	T13 Backstage (or equivalent catalog)	Registered, versioned, approved
TP-02 Tool access control	T1 OPA; T14	Least-privilege per agent identity
TP-03 API gateway security	T11 Kong/Envoy/Cloudflare	

Control	Tool / Process	Notes
		Schema validation, rate limiting, audit
TP-04 Tool output validation	T1 OPA + T12 MCP gateway	Structural validation and sanitisation
TP-05 Pipeline integrity	T9 Sigstore; T27 CI; T10 SBOM	Signed, attested, gated pipelines
TP-06 Dependency scanning	T10 Syft+Grype/Trivy/Snyk	Continuous scanning; sandbox-library high-risk class
TP-07 Cross-tool dependency analysis	P14 (custom process) + T1 (emergent)	Escape-chain analysis; no mature commercial tool
TP-08 Gateway infrastructure-isolation mode	T11 (allow-list config) + T1 OPA	Block control-plane APIs by default
TP-09 Explicit tool registration	T13 + T1; framework auto-registration disabled	No implicit exposure
TP-10 Inbound control-plane protection	T26 IaC security + T11 + custom binding policy	Emerging; network-binding deny defaults
TP-11 Browser/content-rendering isolation	T7 (partial) + custom rendering-layer controls	No mature tool; hidden-content scanning + origin-isolation policy, custom

A5. Monitoring, Logging, and Incident Response (MIR-01 .. MIR-06)

Control	Tool / Process	Notes
MIR-01 Agent activity logging	T20 OpenTelemetry; T18 Langfuse	Every action, tool call, delegation
MIR-02 Behavioural anomaly detection	T19 SIEM (ML)	Per-agent baselines, deviation alerts
MIR-03 Prompt audit log	T18 Langfuse/LangSmith	Sanitised prompt/response capture
MIR-04 Incident response playbooks	P7 (process)	AI-specific IR procedures
MIR-05 Mandatory reporting integration	P8 (runbooks) + T19 (automation)	SOCI 12h / APRA 72h triggers
MIR-06 Forensic readiness	T20 append-only storage (S3 Object Lock)	Immutable logs, session reconstruction

A6. Governance and Risk (GRM-01 .. GRM-06)

Control	Tool / Process	Notes
GRM-01 AI governance body	P1 (charter/committee)	CISO, CRO, GC, data owner, AI lead
GRM-02 AI risk register	P2 (register + kill-switch exercise)	Annual rehearsed kill switch
GRM-03 Ethical use policy	P3 (policy)	Acceptable use boundaries
	P4 (vendor assessment)	

Control	Tool / Process	Notes
GRM-04 Third-party AI risk management		Model/tool/ harness vendors, right-to-audit
GRM-05 Regulatory mapping	T22 Vanta/Drata-class (mapping)	Automated mapping to ISM/ E8/SOCI/APRA/ PSPF
GRM-06 Board and executive reporting	T23 Grafana/Power BI dashboards	Maturity scores, open findings, risk acceptance

A7. Execution Environment (EE-01 .. EE-08)

Control	Tool / Process	Notes
EE-01 Execution boundary enforcement	T24 gVisor/Kata/Firecracker/Nitro Enclaves	No shared mounts/ namespaces, immutable infra
EE-02 Infrastructure API access control	T1 OPA; T21 Kyverno/Gatekeeper	No implicit cloud-API access
EE-03 Resource usage limiting	T21 K8s ResourceQuota; cgroups	Bounded CPU/ memory/network; alerts on exceed
EE-04 Evaluation sandbox integrity	T25 attestation + T26 IaC (network isolation)	Eval/prod separation, no network path
EE-05 Config-file injection prevention	T23 FIM (Wazuh/Tripwire/AIDE) + read-only mounts	Write-path allowlists, integrity monitoring
EE-06 Fail-closed sandbox operation	T25 attestation; T21 policy	Runtime isolation attestation, no fallback
	T23 FIM + T26 (read-only config) + custom	

Control	Tool / Process	Notes
EE-07 Control-plane configuration integrity		Config files read-only to the agent
EE-08 Evaluation-harness isolation	P10 (verification process) + T25 attestation	Egress blocked at hypervisor boundary, verified

Part B: Tool Catalogue with Six Hat Analyses

T1. Open Policy Agent (OPA) and Rego

Hat	Assessment with respect to SHIELD-AI
White	Open-source policy engine; declarative Rego policies evaluated against JSON inputs; runs as a sidecar/daemon or embedded; the SHIELD-AI reference implementation already uses it for its 59 controls
Black	Rego has a learning curve; policy drift is a standing risk if policies are not versioned and tested; a mis-scoped `allow` rule defaults to deny only if written that way; performance needs care at high request rates; not a data-access enforcer by itself
Yellow	Directly implements the deny-override evaluation model the framework demands; every SHIELD-AI control can be expressed as a Rego assertion; testable (`opa test`), auditable, versionable; no vendor lock-in
Red	The natural centre of gravity for this framework. Teams that adopt it early get the most leverage; teams that bolt it on late find it disruptive
Green	Use OPA as the *single* decision point for TP-02, IAM-02/07, MS-08, and EE-02, then generate per-control test suites from the control schema JSON so policy tests stay in lockstep with framework versions
Blue	**Adopt.** Controls: IAM-02, IAM-07, TP-02, TP-04, TP-08, MS-08, EE-02. The reference implementation's engine
Links	openpolicyagent.org

Hat	Assessment with respect to SHIELD-AI
Options	Commercial: Styra DAS (managed OPA control plane), Permit.io

T2. SPIFFE/SPIRE

Hat	Assessment
White	Workload identity standard (SPIFFE) with SPIRE as the reference implementation; issues short-lived X.509 SVIDs to workloads; cloud-native and VM support
Black	Operationally nontrivial to run at scale; requires agent frameworks to support workload identity (not all do); doesn't cover human identity; identity is only as good as the attestation
Yellow	Gives every agent a distinct, auditable identity (IAM-01) with short-lived certificates (IAM-05-adjacent); SVID chaining supports reconstructable delegation chains (IAM-07); no shared human credentials
Red	Feels like the right foundation; can also feel like a platform migration for teams with agent platforms that ignore workload identity
Green	Use SVID token chaining for the two-hop delegation bound: human identity + agent SVID + tool audience, all reconstructable from audit logs
Blue	**Adopt** for agent identity. Controls: IAM-01, IAM-04, IAM-07 (partial)
Links	spiffe.io
Options	Commercial: cloud identity brokers / enterprise SPIFFE support

T3. HashiCorp Vault

Hat	Assessment
White	Secrets manager; dynamic secrets, short TTLs, revocation, encryption-as-a-service (Transit); ubiquitous enterprise adoption

Hat	Assessment
Black	Runs a stateful service needing its own hardening (HA, unseal); secrets sprawl if namespaces are not disciplined; dynamic-secret support varies by backend; teams often store long-lived tokens anyway, defeating IAM-05
Yellow	Implements credential isolation (IAM-04), just-in-time access (IAM-05), and credential scope narrowing (IAM-08) out of the box; per-tool roles and lease revocation cascade naturally through delegation chains
Red	Boring and dependable. The least glamorous and most likely to actually be run
Green	Key every agent session to a Vault dynamic secret with a TTL equal to the session; revoke the whole chain on any incident via lease revocation, satisfying MIR-04's tool revocation step
Blue	**Adopt.** Controls: IAM-04, IAM-05, IAM-08, MS-01 (Transit)
Links	HashiCorp Vault
Options	Commercial: Vault Enterprise; Akeyless; Doppler; CyberArk Conjur

T4. Cloud HSM / KMS (AWS KMS, Azure Key Vault, GCP Cloud KMS, Vault Transit)

Hat	Assessment
White	Cloud key-management services with FIPS-validated HSM options; envelope encryption; BYOK
Black	Cost adds up; key policy misconfiguration is a classic breach vector; HSM-backed keys slow some pipelines; multi-cloud inconsistency
Yellow	Directly implements MS-01 (weight protection with HSM-backed keys at L3+) and DS-02 (encryption in transit); integrates with every other storage/registry tool in this map
Red	Assumed, not exciting. Nobody presents HSM/KMS as innovation; everybody expects it to be there

Hat	Assessment
Green	Use KMS for model-weight envelope encryption with separate data keys per model version, so MS-03 lineage and MS-01 protection share one mechanism
Blue	**Adopt.** Controls: MS-01, DS-02, IAM-05 (adjacent)
Links	AWS KMS
Options	Commercial: AWS KMS + CloudHSM; Azure Key Vault + Managed HSM; GCP Cloud KMS + Cloud HSM

T5. MLflow Model Registry (or equivalent) with Signed Artifacts

Hat	Assessment
White	Model lifecycle registry: versions, stages, lineage metadata; widely deployed for ML lifecycle management
Black	Model registry without signing is just metadata; registry permissions are often an afterthought; MLflow's default auth is weak, so it must be fronted by the identity plane
Yellow	Implements MS-06 (inventory and lineage) and, combined with T9 Sigstore, MS-03 (signed checkpoints, SBOM)
Red	Competent but uninspiring; the value comes from wiring signing and identity into it, which most teams skip
Green	Require a signed provenance attestation (SLSA-style) on every model stage promotion, so the registry becomes the enforcement point for MS-03
Blue	**Adopt with adaptation.** Controls: MS-06, MS-03 (with T9)
Links	mlflow.org
Options	Commercial: Databricks (managed MLflow); W&B Registry; Neptune

T6. Garak / PyRIT / Adversarial Robustness Toolbox

Hat	Assessment
White	Open-source LLM vulnerability scanners: Garak (probes for prompt injection, jailbreaks, data leakage), PyRIT (Microsoft, automated red-teaming), ART (IBM, adversarial ML library)
Black	Test coverage is only as good as the probe library; scanners can produce false positives that erode trust in the pipeline; running them well requires prompt-engineering skill; none cover imperceptible-content vectors fully yet
Yellow	Implements MS-04 (adversarial robustness testing) with CI integration; PyRIT and Garak are actively maintained; cheap to start
Red	The kind of tool that gets run once and forgotten unless it is wired into CI with a pass/fail gate
Green	Run Garak/PyRIT in the model-evaluation pipeline with a regression gate: a model version that fails known probes cannot promote (ties to MS-03 signing and T5)
Blue	**Adopt** as the MS-04 testing layer. Controls: MS-04
Links	Garak
Options	Commercial: Azure AI Foundry red-teaming; Prompt Security; Lakera

T7. promptfoo (or equivalent LLM evaluation harness)

Hat	Assessment
White	LLM evaluation and red-teaming harness; prompt suites, assertion-based grading, CI integration
Black	Evaluations drift as models update; assertion design is skilled work; primarily tests behaviour, not containment
Yellow	

Hat	Assessment
	Implements MS-04 testing and supports MS-05 (behavioural validation) with deterministic assertions; developer-friendly; cheap
Red	A developer tool that security teams inherit; the skills transfer is usually one way and the suites age
Green	Bind approval-gate tests to promptfoo suites: the same suites that block a model version also produce the evidence a human approver signs off on (MS-09 snapshot logic in miniature)
Blue	**Adopt.** Controls: MS-04, MS-05 (partial)
Links	promptfoo.dev
Options	Commercial: Braintrust; LangSmith eval; Galileo

T8. Guardrails (NVIDIA NeMo Guardrails / Guardrails AI / LLM Guard)

Hat	Assessment
White	Runtime guardrail layers that filter model input/output: topic rails, jailbreak rails, PII filters, schema enforcement
Black	Guardrails are defeatable by design (prompt injection can bypass; rails are heuristics); latency overhead on every call; false positives block legitimate use and get tuned off; not a containment control
Yellow	Implements MS-05 (output guardrails and behavioural bounds) at the API layer; some ship with the MCP/agent frameworks in use; cheap to deploy
Red	Loved until the first false positive blocks a demo, then quietly disabled. The Black Hat's "config drift" risk is existential here
Green	Treat guardrails as the *first* filter, with the OPA policy engine as the *authoritative* decision layer behind them, so a disabled rail degrades detection, not enforcement
Blue	**Adopt with adaptation.** Controls: MS-05, DS-06 (partial)
Links	NeMo Guardrails

Hat	Assessment
Options	Commercial: Lakera Guard; Prompt Security; OpenAI Moderation API

T9. Sigstore / cosign

Hat	Assessment
White	Open-source software signing and transparency: cosign signs artifacts, Fulcio issues short-lived certificates, Rekor gives transparency logs
Black	Signing without verification is theatre; keyless flow needs network access to transparency infrastructure; adoption in model-artifact world is immature
Yellow	Implements TP-05 (pipeline attestation) and MS-03 (signed checkpoints); the same mechanism covers DS-07 (agent-authored artifacts enter the signing pipeline)
Red	The right tool that most ML pipelines do not yet run. The framework can change that
Green	Route every agent-originated artifact (DS-07) through cosign signing and Rekor transparency before publication, making agent publication indistinguishable from third-party vetting
Blue	**Adopt.** Controls: TP-05, MS-03, DS-07 (with P13)
Links	sigstore.dev
Options	Commercial: Chainguard (managed Sigstore services)

T10. SBOM and Dependency Scanning (Syft+Grype / Trivy / Snyk / Dependency-Track)

Hat	Assessment
White	Software composition analysis: generate SBOMs (Syft), scan for known vulnerabilities (Grype/Trivy/Snyk), track in a server (Dependency-Track)

Hat	Assessment
Black	False positives and noise are the norm; scans miss logic bugs entirely; sandbox-library classification (TP-06's high-risk class) is not a stock feature of any of them; scanner coverage of model/MCP dependencies is patchy
Yellow	Implements TP-06 directly, including CI blocking on critical findings; Dependency-Track gives the audit trail MIR-06 wants; cheap
Red	The noise problem makes this the tool security teams love to hate, but stopping is not an option
Green	Encode TP-06's sandbox-library rule (vm2, Pyodide, Wasmtime, n8n, interpreter-isolation packages) as a custom vulnerability profile applied by Dependency-Track, so the framework's high-risk class is enforced, not advisory
Blue	**Adopt.** Controls: TP-06, TP-05 (SBOM)
Links	Syft
Options	Commercial: Snyk; Sonatype Nexus Lifecycle; JFrog Xray; GitHub Advanced Security

T11. API Gateways (Kong / Envoy / Cloudflare API Gateway)

Hat	Assessment
White	Mature API gateways: schema validation, rate limiting, authN/authZ, observability; Envoy as the data-plane workhorse, Kong/Tyk/Cloudflare as control planes
Black	Gateway policy is only as good as its config; a gateway that proxies everything is a gateway that authorises nothing; teams add endpoints outside the gateway; control-plane exclusion lists (TP-08) must be actively maintained
Yellow	Implements TP-03 (schema validation, rate limits, audit) and TP-08 (infrastructure-isolation mode via allow-lists); the natural host for the SHIELD-AI tool gateway/sidecar

Hat	Assessment
Red	Mature, trusted, and slightly boring. That is exactly what a production AI boundary should feel like
Green	Enforce TP-08 by deriving the gateway allow-list from the TP-01 tool registry: no tool, no route, and any attempt to reach a non-tool API is an MIR-01 alert
Blue	**Adopt.** Controls: TP-03, TP-08, DS-02, TP-02 (adjacent)
Links	Kong
Options	Commercial: Kong Enterprise; Tyk Enterprise; NGINX Plus; Cloudflare API Gateway

T12. MCP Tooling (MCP Inspector + the SHIELD-AI MCP gateway)

Hat	Assessment
White	MCP Inspector is the official debugging/inspection tool for MCP servers; the SHIELD-AI reference implementation ships an authenticated MCP gateway that validates schema, rate-limits, and logs every MCP interaction
Black	MCP ecosystem is moving fast; tool-metadata signing (MS-08) is not yet standard across servers; a gateway is only as good as the registry feeding it (TP-01); protocol-layer attacks evolve quickly
Yellow	Implements MS-08 (MCP security controls) and TP-04 (output validation) where nothing mature exists; the gateway pattern is the framework's own TP-01/TP-09 enforcement point
Red	Early and a little rough, but it is the right shape: the framework is effectively defining this category
Green	Add signed tool-metadata verification (MS-08) to the gateway, so tool descriptions are cryptographically verified before the agent sees them, and log every MCP write to execution-bearing registries with alerting (EE-07, MIR-01)
Blue	

Hat	Assessment
	Adopt (gateway) / **use** (Inspector). Controls: MS-08, TP-04, TP-09 (with T13)
Links	modelcontextprotocol.io
Options	Commercial: emerging MCP security vendors (2026), none mature - watch the SHIELD-AI watchlist

T13. Backstage (Software Catalog) as Tool Registry

Hat	Assessment
White	Backstage is an open platform for developer portals with a software catalog; entities, metadata, ownership, and integrations
Black	Backstage is heavy to operate; out of the box it is a developer portal, not a security registry; every agent-accessible tool must actually be registered there, which is an ownership problem, not a tool problem
Yellow	Implements TP-01 (tool inventory and registry) and TP-09 (explicit registration) when wired to the gateway allow-list: no catalog entry, no tool route
Red	Developers tolerate it; security teams tend to over-engineer it. Keep the catalog thin
Green	Make the TP-01 registry the source of truth that generates the gateway allow-list (T11) and the OPA tool-permission policies (T1), so three controls are driven by one catalog
Blue	**Adopt with adaptation.** Controls: TP-01, TP-09, TP-02 (with T1)
Links	backstage.io
Options	Commercial: Atlassian Compass; Port; Cortex

T14. Fine-Grained Authorization (OpenFGA / Cedar)

Hat	Assessment
White	Relationship-based authorization: OpenFGA (Zanzibar-inspired), AWS Cedar (embeddable policy language); model relationships and fine-grained checks
Black	Modelling effort is real; teams underestimate the schema design work; not a replacement for OPA-style attribute policy (they complement); operational surface for self-hosted OpenFGA
Yellow	Implements IAM-02 (scope-bound delegation) and DS-04 (field-level data minimisation) at the retrieval layer; IAM-09 tenant scoping via relationship tuples (tenant ID in every check)
Red	Powerful and underused. The modelling investment scares teams into ACLs, which is exactly the failure the framework warns about
Green	Model the two-hop delegation bound as relationship tuples (user -> agent -> tool), so IAM-07's chain cap is an authorization fact, not a policy hope
Blue	**Adopt.** Controls: IAM-02, DS-04, IAM-09, IAM-07 (partial)
Links	openfga.dev
Options	Commercial: Auth0 FGA (Okta); AuthZed; Permit.io; Oso; Cerbos

T15. Vector Databases with Session Scoping (Pinecone / pgvector / Weaviate)

Hat	Assessment
White	Vector stores for retrieval-augmented generation; namespaces/ collections; metadata filters; pgvector embedded in Postgres
Black	Memory is the easy thing to forget: sessions, namespaces, and index copies accumulate; retrieval-layer filtering is only as good as the embedding metadata; many RAG pipelines bypass the vector store for raw data

Hat	Assessment
Yellow	Implements DS-03 (memory sanitisation via session-scoped namespaces with deletion) and DS-04 (field-level filtering at retrieval); pgvector keeps it inside existing DB controls
Red	Quietly dangerous if ignored, quietly effective if automated. Nobody celebrates a vector DB, but a leaked one is career-ending
Green	Tie namespace lifecycle to the agent session (IAM-06): session start creates the namespace, session end deletes it, and any cross-session reference is an anomaly alert (MIR-02)
Blue	**Adopt.** Controls: DS-03, DS-04, IAM-06
Links	Pinecone
Options	Commercial: Pinecone; Weaviate Cloud; Qdrant Cloud; Chroma Cloud

T16. Data Classification Platforms (Microsoft Purview / BigID / AWS Macie)

Hat	Assessment
White	Enterprise data-discovery and classification: scan data stores, auto-tag sensitive data (PII, financial), policy triggers
Black	Classification accuracy varies; coverage depends on connectors; costs scale with data volume; labels only matter if something enforces them
Yellow	Implements DS-01 (automated tagging at ingestion) using the fund/agency classification schema; Macie is cheap to start on AWS
Red	The classic “buy the platform, skip the policy” trap. The tool is the easy half
Green	Pipe DS-01 labels into T14 OpenFGA as metadata filters, so classification drives retrieval scoping (DS-04) automatically
Blue	**Adopt.** Controls: DS-01, DS-04 (adjacent)

Hat	Assessment
Links	Microsoft Purview
Options	Commercial: Purview; BigID; Securiti; Varonis; GCP Sensitive Data Protection

T17. Data Loss Prevention (Purview DLP / Netskope / Symantec DLP)

Hat	Assessment
White	DLP platforms that inspect data in motion and at rest against sensitive-data policies
Black	DLP misses model output that is paraphrased or transformed; encryption defeats inspection; false positives and tuning burden; agents that call external APIs may bypass the DLP inspection point entirely
Yellow	Implements DS-06 (output validation for leakage) for the flows it can see; agent API traffic can be routed through it at the gateway (T11)
Red	Security teams run it, hate tuning it, and quietly rely on it more than they admit
Green	Route agent tool-call responses through the gateway with DLP inspection inline, so DS-06 covers tool output rather than just chat output
Blue	**Adopt with adaptation.** Controls: DS-06
Links	Netskope
Options	Commercial: Purview DLP; Netskope; Symantec; Forcepoint; Zscaler

T18. LLM Observability (Langfuse / LangSmith / Helicone)

Hat	Assessment
White	Tracing and observability for LLM applications: prompts, responses, tool calls, sessions, latency, cost; Langfuse is self-hostable and open source
Black	Tracing captures sensitive content by design, so it must be treated as a sensitive store (redaction is the operator's job); integrations assume the framework's SDK; traces are only as good as the instrumentation
Yellow	Implements MIR-01 (agent activity logging) and MIR-03 (prompt audit log with redaction) at the application layer; session reconstruction for MIR-06 comes almost for free
Red	The most natural monitoring surface an agent team will actually adopt. Use it before fighting for SIEM coverage
Green	Emit a per-session trace ID from the Langfuse trace into the SIEM (T19) and the append-only store (T20), so MIR-01 logs and MIR-06 evidence are joined across systems
Blue	**Adopt.** Controls: MIR-01, MIR-03, MIR-06 (partial)
Links	Langfuse
Options	Commercial: LangSmith; Helicone; Datadog LLM Observability; W&B Weave; Langfuse Cloud

T19. SIEM (Splunk / Microsoft Sentinel / Elastic)

Hat	Assessment
White	Security information and event management: log aggregation, correlation rules, ML anomaly detection, alerting, dashboards
Black	SIEMs are only as good as the logs fed to them; agent activity rarely lands there without a pipeline; license cost scales with ingestion; anomaly detection needs baselines and tuning

Hat	Assessment
Yellow	Implements MIR-02 (behavioural anomaly detection on per-agent baselines) and hosts MIR-05 reporting triggers; the natural home for MIR-06 reconstruction queries
Red	The place security teams already live. If agent logs do not reach it, the agents are invisible, which is the worst possible state
Green	Define per-agent baseline profiles (normal tool mix, normal latency, normal data volume) and alert on deviation, satisfying MIR-02 without bespoke ML
Blue	**Adopt.** Controls: MIR-02, MIR-05, MIR-06 (partial)
Links	Splunk
Options	Commercial: Splunk; Sentinel; CrowdStrike Falcon; Palo Alto XSIAM; Datadog Cloud SIEM

T20. OpenTelemetry + Grafana/Loki + Append-Only Storage (S3 Object Lock / WORM)

Hat	Assessment
White	OpenTelemetry for unified telemetry collection; Grafana/Loki for log storage/query; S3 Object Lock (or similar WORM storage) for immutable retention
Black	Pipeline engineering burden is real; WORM configuration mistakes are irreversible (which is the point, and the risk); retention costs; replayability of agent sessions requires structured logs, not just text
Yellow	Implements MIR-01 (activity logging) at the infrastructure layer and MIR-06 (forensic readiness with immutable, append-only logs and full session reconstruction)
Red	Plumbing. Unloved, necessary, and the difference between an investigation and a shrug
Green	Write every OTel agent-action span to Object-Lock-enabled storage with a session ID, so MIR-06 reconstruction is a query, not a forensic project

Hat	Assessment
Blue	**Adopt.** Controls: MIR-01, MIR-06
Links	opentelemetry.io
Options	Commercial: Grafana Cloud; Datadog; New Relic; Chronosphere

T21. Kubernetes Policy and Isolation (OPA Gatekeeper / Kyverno / NetworkPolicy / ResourceQuota)

Hat	Assessment
White	Cluster policy engines (Gatekeeper, Kyverno) enforcing admission policies; NetworkPolicy for pod isolation; ResourceQuota/limits for bounds
Black	Policy engines are bypassed by teams with cluster-admin; default-deny network policies break apps and get loosened; Kyverno/Gatekeeper policy drift is a standing cost; not applicable if the estate is not Kubernetes
Yellow	Implements EE-02 (no implicit infrastructure-API access via policy) and EE-03 (resource limiting) directly; NetworkPolicy supports the network-boundary model for EE-01
Red	Standard, expected, and routinely weakened in production. The framework's fail-closed stance (EE-06) exists because of this pattern
Green	Combine Kyverno image-verification (Sigstore) with the tool registry: only signed, registry-approved tool images run, binding TP-05 to EE-01
Blue	**Adopt** where Kubernetes. Controls: EE-02, EE-03, EE-01 (partial)
Links	OPA Gatekeeper
Options	Commercial: Sysdig; Aqua; Prisma Cloud; Snyk

T22. Compliance Mapping Platforms (Vanta / Drata / Secureframe)

Hat	Assessment
White	Continuous compliance automation: evidence collection, framework mappings, control tests, reporting
Black	Mapping quality varies by framework; these platforms have no SHIELD-AI pack yet; they prove evidence, not security; subscription cost
Yellow	Implements GRM-05 (automated regulatory mapping to ISM/E8/SOCI/APRA/PSPF/Privacy Act) once a SHIELD-AI mapping pack is added; quarterly posture reports become a scheduled export
Red	Management-friendly, engineer-tolerated. The mapping work is the real cost and it is custom
Green	Publish a SHIELD-AI-to-ISM/E8/CPS 234 mapping pack (from the framework's regulatory tables) usable by these platforms, turning GRM-05 into a supported integration
Blue	**Adopt with adaptation.** Controls: GRM-05
Links	Vanta
Options	Commercial: Vanta; Drata; Secureframe; OneTrust; Archer; ServiceNow IRM

T23. File Integrity Monitoring (Wazuh FIM / Tripwire / AIDE)

Hat	Assessment
White	FIM tools watch filesystem paths for changes against a known-good baseline; Wazuh is open source and well integrated with SIEM
Black	

Hat	Assessment
	FIM noise on high-churn paths; baseline drift; monitoring agent config files (EE-05/07) requires careful path selection; agents running in sandboxes may not be observable by host FIM
Yellow	Implements EE-05 (host-trusted config-file injection prevention via write-path allowlists + integrity monitoring) and EE-07 (control-plane configuration integrity, detecting writes to .codex/, .claude/, .cursor/, MCP registries)
Red	Quiet background work. It only gets attention when it fires, and firing is the point
Green	Focus FIM on the exact EE-05/07 path list (shell profiles, IDE settings, virtualenv wrappers, cron/systemd, MCP registries) and alert, not just log, because a log without alerting is not a control
Blue	**Adopt.** Controls: EE-05, EE-07 (partial)
Links	Wazuh
Options	Commercial: Tripwire Enterprise; Qualys; CrowdStrike Falcon; Tanium

T24. Sandbox Runtimes (gVisor / Kata Containers / Firecracker / AWS Nitro Enclaves)

Hat	Assessment
White	Strong-isolation runtimes: gVisor (userspace kernel), Kata (lightweight VM), Firecracker (microVM), Nitro Enclaves (hardware-isolated enclaves)
Black	Performance overhead; ecosystem compatibility (some agent frameworks assume plain containers); gVisor is not a security boundary by itself (it is a compatibility layer with a security goal); enclaves complicate debugging and tooling
Yellow	Implements EE-01 (execution environment boundary enforcement) with real isolation; Nitro Enclaves add attestation, which feeds EE-06
Red	

Hat	Assessment
	The honest answer to “can the sandbox be escaped?”: fewer ways out, and each one costs the attacker more
Green	Run LLM-generated code execution in gVisor or Kata with no host mounts (EE-01), and keep the evaluation harness in a separate enclave profile so EE-04/08 boundaries are physical, not configurational
Blue	**Adopt.** Controls: EE-01, EE-04 (partial), EE-08 (partial)
Links	gVisor
Options	Commercial: AWS Nitro Enclaves; Azure Confidential Computing; GCP Confidential VMs

T25. Attestation (AWS Nitro Attestation / SEV-SNP & TDX / Keylime)

Hat	Assessment
White	Hardware/VM attestation: cryptographic proof that an environment is what it claims (Nitro attestation documents, AMD SEV-SNP, Intel TDX, Keylime for TPM-based attestation)
Black	Attestation infrastructure is immature operationally; policies must decide what constitutes a trusted measurement; attestation is a snapshot, not continuous (though replay can close that); platform-specific
Yellow	Implements EE-06 (fail-closed sandbox operation via runtime attestation) and strengthens EE-08 (evaluation-harness isolation verification); the mechanism behind “no verified egress block means no evaluation”
Red	The difference between asserting isolation and proving it. The framework’s EE-08 stance is built on this distinction
Green	Make code-execution steps require a valid attestation token before each run, so EE-06’s “verify before execute” is mechanical, not aspirational
Blue	**Adopt** at L3+. Controls: EE-06, EE-08 (partial), EE-04 (partial)

Hat	Assessment
Links	Keylime
Options	Commercial: AWS Nitro Attestation; Azure Attestation; GCP Confidential VM attestation

T26. Infrastructure-as-Code Security (Checkov / tfsec / OpenTofu policy)

Hat	Assessment
White	Static analysis of IaC (Terraform/OpenTofu/CloudFormation): misconfigurations, exposed ports, missing encryption, network topology
Black	IaC scanning finds what the template says, not what the environment is (drift); gate placement matters; does not cover runtime
Yellow	Implements EE-04 (evaluation sandbox network isolation) and TP-10 (network-binding deny defaults) as code, so the network-boundary model is reviewable in PRs
Red	The kind of control that works until drift, which is why the framework pairs it with runtime verification (EE-06)
Green	Encode the network-boundary model (enclave, air-gap, sidecar) as tested IaC modules with Checkov policies, so TP-10/EE-04 are the default, not the exception
Blue	**Adopt.** Controls: EE-04, TP-10 (partial), EE-01 (partial)
Links	Checkov
Options	Commercial: Snyk IaC; Prisma Cloud; Wiz; Aqua; Tenable

T27. Git-native CI Gates (GitHub Actions / GitLab CI with branch protection)

Hat	Assessment
White	CI/CD platforms with branch protection, required reviews, signed commits, and reusable workflow gates
Black	CI gates are bypassed by direct pushes to registries; required approvals become rubber stamps; agents committing through CI create a new review-pressure surface (the Mythos 5 pattern)
Yellow	Implements IAM-03 (approval gates for high-risk actions), TP-05 (pipeline integrity), and hosts the DS-07 publication approval workflow as a hard gate the agent cannot invoke
Red	The boring infrastructure that makes every other control in this map deployable. Neglect it and nothing else holds
Green	Make DS-07's out-of-band approval a CI environment that requires a human-issued token: agent-initiated publication simply cannot satisfy it
Blue	**Adopt.** Controls: IAM-03, TP-05, DS-07 (with P13)
Links	GitHub Actions
Options	Commercial: GitHub Enterprise; GitLab EE; Azure DevOps; CircleCI; Buildkite

Part C: Process Catalogue (with Hat Assessments)

P1. AI Governance Body Charter (GRM-01)

Hat	Assessment
White	Chartered committee: CISO, CRO, General Counsel, data owner, AI lead; terms of reference including agentic-AI approval authority

Hat	Assessment
Black	Committees drift into ceremony; without a decision register and escalation path, the charter is a document
Yellow	The only realistic owner of risk-acceptance decisions; CPS 234 board-accountability alignment
Red	The difference between an organisation that treats AI security as a program and one that treats it as a project
Green	Give the body a standing agenda item: kill-switch exercise results and watchlist promotions, keeping GRM-02/GRM-06 alive
Blue	**Process.** Mandatory. No tool substitutes it
Links	APRA CPS 234

P2. AI Risk Register and Kill-Switch Exercise (GRM-02)

Hat	Assessment
White	AI-specific risk register with automated tripwires and one rehearsed kill switch, exercised at least annually
Black	Registers rot; kill switches fail in anger when they are menus of untested responses
Yellow	The control that makes machine-speed response possible; a single rehearsed red button
Red	The kill-switch exercise is the most uncomfortable hour on the calendar and the most valuable
Green	Rehearse the kill switch against a live sandboxed agent, not a slide deck, so the drill is real
Blue	**Process.** Mandatory
Links	APRA CPS 234

P3. Ethical Use Policy (GRM-03)

Hat	Assessment
White	Acceptable-use boundaries: what agents may and may not do; human-in-the-loop by risk tier; transparency obligations
Black	Policy without enforcement is advisory; writing it is the easy 10%
Yellow	Feeds the OPA policy set (T1) with the normative positions; gives the governance body its decision basis
Red	Dull, necessary, and the thing auditors ask for first
Green	Derive the deny-first policy assertions directly from the ethical-use positions, so policy text and enforcement share one source
Blue	**Process.** Mandatory
Links	Australian AI Ethics Framework

P4. Third-Party AI Vendor Assessment (GRM-04)

Hat	Assessment
White	Vendor security assessment for model providers, tool providers, evaluation-harness vendors; right-to-audit clauses; CPG 230 alignment
Black	Assessments are point-in-time; vendor responses are self-reports; evaluation-harness vendors are a category most programs do not assess at all
Yellow	Covers the supply-chain third of the framework; the harness-vendor angle (EE-08) is uniquely SHIELD-AI
Red	Unloved procurement work with an outsized risk payoff
Green	Add a harness-isolation assurance questionnaire (EE-08) to every evaluation-vendor contract, and require egress-block verification evidence
Blue	**Process.** Mandatory

Hat	Assessment
Links	APRA CPG 230

P5. Board and Executive Reporting Cadence (GRM-06)

Hat	Assessment
White	Standardised dashboard: maturity scores per pillar, open findings, regulatory status, risk-acceptance decisions
Black	Dashboards without decision rights are decoration; quarterly cadence can lag agent-speed risk
Yellow	Gives the trustee/board the line of sight CPS 234 and the framework's governance pillar demand; turns posture into a trend
Red	The report the board actually reads changes the program's trajectory
Green	Automate the dashboard from the OPA test suite and control-schema JSON, so maturity scores update with every policy change
Blue	**Process** (+ T22/T23 for automation). Mandatory
Links	APRA CPS 234 (board accountability)

P6. Training Data Governance Process (DS-05)

Hat	Assessment
White	Data lineage, consent verification, retention limits on training datasets
Black	Data lineage tooling is immature for the ML world; most organisations cannot answer "what trained this model"
Yellow	Closes the data-governance gap that DS-01 tagging feeds; Privacy Act APP 11 relevance

Hat	Assessment
Red	The least glamorous process in the framework and one of the most likely to be skipped
Green	Reuse the DS-01 classification pipeline output as the lineage ledger’s input, so governance is a by-product of classification
Blue	**Process.** Mandatory
Links	Australian Privacy Act / APPs

P7. AI-Specific Incident Response Playbooks (MIR-04)

Hat	Assessment
White	IR procedures distinct from general IR: prompt-injection containment, model rollback, tool revocation, session invalidation
Black	Playbooks age; the four procedures must be drilled or they are fiction
Yellow	The difference between an incident and a breach; MIR-05 reporting depends on them
Red	The playbooks people actually open during an incident are the ones that were drilled
Green	Automate the four steps where possible: Vault lease revocation (T3), gateway route kill (T11), session namespace deletion (T15)
Blue	**Process** (+ T3/T11/T15 automation). Mandatory
Links	NIST AI RMF

P8. Mandatory Reporting Runbooks (MIR-05)

Hat	Assessment
White	

Hat	Assessment
	Automated triggers for SOCI 12-hour and APRA 72-hour notification windows; pre-populated templates
Black	Notification maths (who is notified when) must be pre-agreed; template staleness
Yellow	Turns an incident into a compliant notification on time; demonstrably protects the entity
Red	Bureaucratic, but the 72-hour clock does not care about bureaucracy
Green	Drive the trigger from SIEM correlation (T19) with a pre-filled draft, so the clock starts automatically
Blue	**Process** (+ T19). Mandatory
Links	SOCI Act (CISC)

P9. Classification Schema Deployment (DS-01)

Hat	Assessment
White	Deploy the organisation's classification schema (PSPF/ISM for agencies, commercial schema for funds) with automated tagging
Black	Classification is only useful if downstream systems enforce it; tagging drift
Yellow	Feeds T16 platforms, T14 scoping, and P6 lineage; the framework's DS-01 is the same schema the entity already runs
Red	The unglamorous foundation everything else stands on
Green	Make DS-01 labels the metadata filter for T14 retrieval checks, closing the loop between classification and minimisation
Blue	**Process.** Mandatory
Links	PSPF

P10. Evaluation-Harness Verification Process (EE-08)

Hat	Assessment
White	Verify evaluation-harness isolation as a control: egress blocked at the hypervisor/namespace boundary and tested before and during runs; domain-collision checks; cryptographic run separation; no verified egress block means no evaluation
Black	This is a custom process; no commercial tool ships it; the incidents (PyPI publication, domain collision, cross-run contamination) show what happens when it is asserted instead of verified
Yellow	The fail-closed control that prevents the entire evaluation-breach class; uniquely SHIELD-AI
Red	Uncomfortable to implement and non-negotiable once you have seen the incident set
Green	Combine T25 attestation with an active egress test (run-time probe that fails the run if any packet escapes) and a domain-collision checker against real asset inventories
Blue	**Custom process** (+ T25, T26). Mandatory
Links	SHIELD-AI framework EE-08

P11. Deployment-Context Obfuscation Process (MS-07)

Hat	Assessment
White	Make evaluation/test environments indistinguishable from production from the model's perspective: same endpoints, data formats, latency, error handling, credential lifetimes; detect divergence
Black	No commercial tool; requires environment instrumentation and behavioural comparison

Hat	Assessment
Yellow	Defeats evaluation-subversion (models acting differently when they detect evaluation); complements EE-04
Red	The control nobody will do voluntarily and the one attackers actively probe
Green	Automate divergence detection: run the same input suite against eval and prod paths and alert on behavioural differences
Blue	**Custom process.** Mandatory
Links	SHIELD-AI framework MS-07

P12. Perception-Fidelity Enforcement Workflow (MS-09)

Hat	Assessment
White	Strip/flag imperceptible content (zero-opacity, 1px, DOM-hidden, hidden PR comments) before reasoning; approvals bind to a rendering-fidelity snapshot of what the human actually sees
Black	Emerging; rendering-fidelity snapshots need bespoke tooling; PDF/HTML rendering engines are attack surface themselves
Yellow	Closes the Kiro-class hole where hidden text defeated human approval; uniquely SHIELD-AI
Red	The control that exists because a real incident proved the human-in-the-loop assumption false
Green	Build snapshot binding into the approval UI: the approver signs a rendered image, not a text extraction
Blue	**Custom workflow** (+ T7 partial). Mandatory
Links	SHIELD-AI framework MS-09

P13. Artifact Publication Approval Workflow (DS-07)

Hat	Assessment
White	Agent-authored artifacts enter the same integrity/signing/ provenance/malware-scan pipeline as third-party artifacts; publication requires out-of-band approval the agent cannot invoke; scoped short-lived credentials
Black	Workflow is only as strong as the credential separation; agent self-publication to channels outside the workflow is the residual risk
Yellow	The supply-chain control that treats agents as producers; combines T9 signing, T27 CI gates, T10 scanning
Red	The Mythos 5 incident made this control inevitable; it is the difference between agents as publishers and agents as vetted contributors
Green	Human-issued CI token per publication (T27), cosign signing + malware scan (T9/T10), and an immutable publication log (T20)
Blue	**Workflow** (+ T9/T10/T27). Mandatory
Links	SHIELD-AI framework DS-07

P14. Cross-Tool Dependency Analysis Process (TP-07)

Hat	Assessment
White	Analyse registered tools for transitive risk: tool combinations enabling escape chains (network_write + code_execution, file_write + network_access); blocking review; risk acceptance via GRM-02
Black	No mature commercial tool; attack-graph analysis is bespoke; the classification of every tool by escape potential is manual upkeep
Yellow	The control that catches the chained-permission failures before deployment; prevents the multi-step escape class

Hat	Assessment
Red	Feels like over-engineering until the first escape chain shows up in a vendor bulletin
Green	Build a small attack-graph checker over the TP-01 registry (tool capability tags + combination rules from TP-07), producing the blocking-review list mechanically
Blue	**Custom process** (+ T1/T13 partial). Mandatory
Links	SHIELD-AI framework TP-07

Part D: Coverage Analysis

D1. Coverage by Maturity of Tooling

Coverage class	Controls	Tools
Mature mainstream tooling	47 of 59	OPA, SPIFFE, Vault, KMS, registries, scanners, gateways, FIM, sandboxes, SIEM, DLP, vector DBs, classification platforms, compliance platforms, IaC security
Emerging but usable	4	MS-08 (MCP gateway), TP-10 (binding policies), MS-04 (imperceptible-content scanning partial), MS-09

Coverage class	Controls	Tools
		(rendering snapshot partial)
Custom / process-only	8	MS-07, MS-09, DS-07 (workflow), TP-07, TP-10, TP-11, EE-07, EE-08

D2. Controls That Need Custom or Emerging Implementation

- **MS-07 Deployment-context obfuscation**: no commercial tool; custom divergence detection (P11)
- **MS-09 Perception-fidelity enforcement**: emerging; custom rendering-fidelity snapshot binding (P12)
- **DS-07 Artifact publication control**: workflow over T9/T10/T27, not a single product (P13)
- **TP-07 Cross-tool dependency analysis**: custom attack-graph checker (P14)
- **TP-10 Inbound control-plane protection**: emerging; network-binding deny policy + gateway token hygiene (T26/T11 + custom)
- **EE-07 Control-plane configuration integrity**: FIM + read-only mounts + MCP-registry monitoring (T23 + custom)
- **EE-08 Evaluation-harness isolation**: attestation + active egress verification, fail-closed (P10 + T25)
- **TP-11 Agent browser/content-rendering isolation**: hidden-content scanning on rendered pages and documents (T7 partial) plus custom origin-isolation policy; no mature tool

These eight are exactly the controls the framework's reference implementation and Rego policy set ship as code, and they are the strongest argument for adopting the reference implementation rather than assembling purely from commercial tools.

Part E: Adoption Roadmap (L1-L4)

E1. L1 to L2 (First Production System)

The floor every production AI system needs before it handles real data:

- Identity and secrets: SPIFFE (T2), Vault with JIT and per-tool scopes (T3)
- Policy: OPA with the SHIELD-AI control set (T1)
- Gateway: API gateway with schema validation and rate limits (T11)
- Execution: sandbox runtime with no host mounts (T24), K8s policy where applicable (T21)
- Data: classification tagging (T16), session-scoped vector store (T15)
- Monitoring: OTel pipeline with append-only storage (T20), LLM tracing (T18), SIEM baseline (T19)
- Governance: governance body, risk register, kill-switch rehearsal (P1, P2)
- Tooling hygiene: SBOM + scanning (T10), CI gates (T27)

E2. L2 to L3 (Defined)

- Model security: model registry with signing (T5+T9), Garak/PyRIT and promptfoo in CI (T6, T7), guardrails behind OPA (T8)
- Authorization: OpenFGA relationship model incl. two-hop delegation (T14)
- Tool control: Backstage registry driving the gateway allow-list (T13), MCP gateway (T12), cross-tool analysis process (P14)
- Enforcement: FIM on EE-05/07 paths (T23), IaC security incl. TP-10 binding policies (T26), DLP inline at gateway (T17)
- Monitoring: per-agent baselines in SIEM (T19), IR playbooks and reporting runbooks drilled (P7, P8)
- Governance: vendor assessment incl. harness vendors (P4), compliance mapping platform with SHIELD-AI pack (T22), board dashboard (P5 + T22/T23)

E3. L3 to L4 (Optimised)

- Continuous red-teaming: automated Garak/PyRIT campaigns against live deployments (T6)
- Attestation everywhere: Nitro/SEV-SNP/TDX attestation before code execution (T25), evaluation-harness verification fail-closed (P10)
- Deployment-context obfuscation and perception-fidelity as standing programs (P11, P12)
- AI-SPM class tools for cross-cutting visibility (Wiz-class) and automated compliance attestation (T22)
- Kill-switch and IR drills at least annually, with the kill switch rehearsed against live sandboxed agents (P2, P7)

E4. Sequencing Principle

Adopt in this order: **identity and policy first (L2 floor), then enforcement (L3), then assurance (L4).** Every control in the later tiers is cheaper to add once identity, policy, logging, and sandboxing exist, because each new tool plugs into the same decision and telemetry planes rather than standing up its own.

Appendix: Tool and Process Index

ID	Tool / Process	Primary controls
T1	OPA + Rego	IAM-02, IAM-07, TP-02, TP-04, TP-08, MS-08, EE-02
T2	SPIFFE/SPIRE	IAM-01, IAM-04, IAM-07 (partial)
T3	HashiCorp Vault	IAM-04, IAM-05, IAM-08, MS-01 (Transit)
T4	HSM/KMS	MS-01, DS-02
T5	MLflow Model Registry + signing	MS-06, MS-03 (with T9)
T6	Garak / PyRIT / ART	MS-04
T7	promptfoo	MS-04, MS-05 (partial)

ID	Tool / Process	Primary controls
T8	NeMo Guardrails / Guardrails AI / LLM Guard	MS-05, DS-06 (partial)
T9	Sigstore / cosign	TP-05, MS-03, DS-07 (with P13)
T10	Syft+Grype / Trivy / Snyk / Dependency-Track	TP-06, TP-05 (SBOM)
T11	API gateways (Kong/Envoy/ Cloudflare)	TP-03, TP-08, DS-02
T12	MCP Inspector + SHIELD-AI MCP gateway	MS-08, TP-04, TP-09 (with T13)
T13	Backstage tool registry	TP-01, TP-09, TP-02 (with T1)
T14	OpenFGA / Cedar	IAM-02, DS-04, IAM-09, IAM-07 (partial)
T15	Vector DBs with session scoping	DS-03, DS-04, IAM-06
T16	Purview / BigID / Macie	DS-01, DS-04 (adjacent)
T17	DLP (Purview / Netskope / Symantec)	DS-06
T18	Langfuse / LangSmith / Helicone	MIR-01, MIR-03, MIR-06 (partial)
T19	SIEM (Splunk / Sentinel / Elastic)	MIR-02, MIR-05, MIR-06 (partial)
T20	OpenTelemetry + Grafana/Loki + Object Lock	MIR-01, MIR-06
T21	OPA Gatekeeper / Kyverno / NetworkPolicy	EE-02, EE-03, EE-01 (partial)
T22	Vanta / Drata / Secureframe	GRM-05
T23	Wazuh FIM / Tripwire / AIDE	EE-05, EE-07 (partial)
T24	gVisor / Kata / Firecracker / Nitro Enclaves	EE-01, EE-04 (partial), EE-08 (partial)
T25	Attestation (Nitro / SEV-SNP / TDX / Keylime)	EE-06, EE-08 (partial), EE-04 (partial)
T26	Checkov / tfsec / OpenTofu policy	EE-04, TP-10 (partial), EE-01 (partial)
T27	Git-native CI gates (GitHub Actions / GitLab CI)	IAM-03, TP-05, DS-07 (with P13)

ID	Tool / Process	Primary controls
P1	AI governance body charter	GRM-01
P2	Risk register + kill-switch exercise	GRM-02
P3	Ethical use policy	GRM-03
P4	Third-party AI vendor assessment	GRM-04
P5	Board/executive reporting cadence	GRM-06
P6	Training data governance	DS-05
P7	AI-specific IR playbooks	MIR-04
P8	Mandatory reporting runbooks	MIR-05
P9	Classification schema deployment	DS-01
P10	Evaluation-harness verification	EE-08
P11	Deployment-context obfuscation	MS-07
P12	Perception-fidelity enforcement	MS-09
P13	Artifact publication approval	DS-07
P14	Cross-tool dependency analysis	TP-07

SHIELD-AI Tooling and Process Map – August 6, 2026 Authored by the Security Architecture Practice